Personae non Gratae and Cyber Essentials

Dr. Ramokapane

University of BRISTOL

Bristol Cyber Security Group

Who are PnGs?

Archetypal Users

Have specific goals

Specific actions to achieve those goals

Modelling helps us think about the ways in which a system may be vulnerable to abuse

As a mechanical engineer, Marvin developed a new design for an implantable cardioverter-defibrillator (ICD) that he planned to patent. However, the MedsRUs Company beat him to the punch and filed a patent for a similar design. MedsRUs is now getting rich and Marvin is feeling cheated and angry at his lost opportunity.

Recently divorced, and without the funds to support the lifestyle he dreamed of, he has become increasingly bitter about his perceived loss.

Marvin's Misuse Cases that Threaten Correct Operation of the ICD

1. Snoop on the data transmitted along the serial cable between the ICDs' reprogramming equipment and communication device in order to retrieve the patient's name, ID, and basic medical history that is all stored in the ICD.
2. Transmit commands to replace the patient's personal information in the ICD.
3. Transmit commands to shut off the device's ability to respond to cardiac events.
4. Transmit commands to switch to test mode so that a carefully timed current triggers an arrhythmic test event that could stop the heart entirely.

Marvin
Mechanic al Engineer
Bitter and revengeful

Goals:

- To undermine the reputation of MedsRUs by disrupting the ICD behavior of random ICD users on the street.
- To accomplish the attack without detection.
- To cause discomfort to ICD users without killing them.

Skills:

- Strong code/hacking skills
- Mechanical engineering/device building skills

Angela is a medical researcher who believes that current practices in heart monitoring and defibrillation are not as effective as they might be. She has run some experiments on lab rats but wishes to experiment with human subjects. She knows that she first needs to go through the process of human-subject research approval, but before doing so, she has decided to try some informal experiments on her own group of patients. This way she can short-circuit the otherwise laborious task of getting her study approved. She needs a breakthrough discovery to boost her career, which has currently stagnated.

Angela
Medical Doctor
Ambitious researcher

Angela's Misuse Cases that Threaten Correct Operation of the ICD

1. Set heart rate cut-off rate and therapy initiation delays to experimental levels outside normal bounds.
2. The ICD stores a record of any changes in setting, therefore Angela will tamper with the ICD command audit log on both the ICD and the external history database to remove all record of the current change in settings.
3. During normal operation, the ICD records pulsing/therapy events and sensor readings. Angela's boyfriend has written code to remove evidence of the illegal study by purging the historical log.

Goals:

- To perform a non-approved study on her patients by testing a variety of non-approved pulsing therapies.
- To cover her tracks by purging her illegal commands from the ICD logs.

Skills:

- Medical training to plan new therapy patterns
- Lacks technical skills to tamper with the ICD command log in order to hide the unorthodox commands she sends to the device. However, she has persuaded her boyfriend, who is a skilled hacker, to write a program to purge entries from the log.

CYBER ESSENTIALS

Minimum baseline standard for cyber security in the UK

Mainly targeted at SMEs (Small and medium-sized Enterprises)

Increasingly a requirement in many contracts

CYBER ESSENTIALS

Firewalls

Secure configuration

User access control

Malware protection

Security update management *(patching!)*

Group Exercise

You are a team of Cyber Security consultants hired by a start-up. The start-up provides intelligent solutions for network traffic analysis as a third-party service. The solutions are highly accurate and the service (hosted in the cloud from a commercial cloud provider) is highly reliable, scalable and, hence, responsive. The success of the solutions has led to massive growth in the company within a short period of time – moving from 4 employees to 30 and from service provision at regional-level to an international customer base, which now includes telecommunications providers, the financial sector as well as some security solution providers.

Your task

1. Working in your allocated group, develop one PnG each.

Group A: Your PnG is Mallory - the office administrator who has been with the company from the start. He is overworked and bitter as all new investment has gone into sales and technical staff.

Group B: Your PnG is Eve - the third party IT consultant hired to help manage the growing IT in the company. She is ambitious and inclined to gain hands on IP to launch a rival company.

Group C: Your PnG is Bob - one of the new sales people. He is always travelling, meeting clients. He doesn't play by the rules and will access sensitive company data from networks in cafes, trains and motorway services.

Group D: Your PnG is Alice - a senior executive who likes to work from her own laptop and phone. She hates the new company laptop and wants to find ways to use her own devices to get the work done.

Group E: Your PnG is Trudy – the former CFO who was replaced after a recent merger. Feeling sidelined and bitter, Trudy still has partial access to sensitive financial data and systems. She is considering ways to exploit her knowledge to sabotage the new CFO or gain leverage for personal gain.

2. Using your PnGs, undertake an analysis against Cyber Essentials to determine which Cyber Essentials controls may mitigate against the misuse cases of the PnG. Also analyse in which misuse cases (if any) Cyber Essentials won’t be sufficient or effective?

You have been provided a copy of the Cyber Essentials Requirements

Outputs

At the end of the session, each group should have a PnG as shown in the examples

Each group should also have a table mapping misuse cases of their PnG against the Cyber Essentials controls

We will put these up on the screen and discuss.